

UNIVERSIDAD DE SAN CARLOS DE GUATEMALA

DIVISIÓN DE CIENCIAS DE LA INGENIERÍA

ÁREA PROFESIONAL

Software Avanzado

Docente: Ing. Moisés Granados



Ensayo: OAuth vs SAML para Delegar Identidad

Carné

201430801

Nombre:

Luis Basilio Baquix Sic

Conceptos Generales

Delegación de Identidad

La delegación de identidad es el mecanismo mediante el cual un sistema permite que un usuario otorgue a una aplicación o servicio permisos para actuar en su nombre, sin necesidad de compartir sus credenciales directamente. En lugar de entregar su contraseña a una aplicación de terceros, el usuario autoriza explícitamente qué acciones puede realizar esa aplicación sobre sus recursos, bajo qué condiciones y por cuánto tiempo.

Este concepto es fundamental en la seguridad moderna porque resuelve un problema estructural: históricamente, las aplicaciones que necesitaban acceder a recursos de otro servicio solicitaban al usuario su nombre de usuario y contraseña, almacenándolos de forma directa. Esto generaba un riesgo de seguridad significativo, ya que un compromiso de la aplicación intermedia exponía directamente las credenciales del usuario. La delegación de identidad elimina este problema al introducir tokens de acceso de alcance limitado en lugar de credenciales completas.

"The problem we're trying to solve is letting a third-party application access resources on behalf of a resource owner without the resource owner sharing their credentials." pág. 4 ¹

Single Sign-On (SSO)

El Single Sign-On, o inicio de sesión único, es una propiedad de los sistemas de autenticación que permite a un usuario autenticarse una sola vez y acceder a múltiples aplicaciones o servicios sin necesidad de volver a ingresar sus credenciales. Desde la perspectiva del usuario, la experiencia es transparente: inicia sesión en un punto central y el acceso al resto de los sistemas se produce de forma automática.

El SSO resuelve un problema organizacional concreto: en entornos corporativos o de múltiples servicios, gestionar credenciales separadas para cada aplicación

¹ Véase OAuth 2.0 in Action, Justin Richer y Antonio Sanso, Manning Publications, capítulo 1, pág. 4.

genera fricción para el usuario, incrementa el riesgo de contraseñas débiles o reutilizadas, y complica la administración de accesos cuando un empleado abandona la organización. Con SSO, revocar el acceso en el proveedor de identidad central es suficiente para desconectar al usuario de todos los servicios asociados. Tanto OAuth 2.0 con OpenID Connect como SAML 2.0 son estándares que, entre otras cosas, habilitan implementaciones de SSO, aunque desde perspectivas y ecosistemas distintos.

Problemática que Resuelven

Antes de la adopción de estos estándares, las aplicaciones que necesitaban interactuar con servicios externos enfrentaban un dilema de seguridad sin solución elegante: o bien solicitaban las credenciales del usuario y las almacenaban, o bien requerían que cada servicio desarrollara su propia solución propietaria de federación de identidad, generando islas de autenticación incompatibles entre sí.

OAuth 2.0 surge principalmente para resolver el problema de la autorización delegada en entornos web y móviles, donde aplicaciones de terceros necesitan acceder a recursos protegidos en nombre del usuario, como publicar en sus redes sociales o leer sus contactos, sin conocer sus credenciales. SAML 2.0, por su parte, surge del contexto empresarial para resolver la federación de identidad entre organizaciones distintas, permitiendo que los empleados de una empresa accedan a servicios externos usando las credenciales corporativas sin necesidad de crear cuentas adicionales. En síntesis, OAuth resuelve la autorización delegada en entornos de consumo, y SAML resuelve la autenticación federada en entornos empresariales.

Ecosistema de Cada Herramienta

OAuth 2.0 nació en el ecosistema de las grandes plataformas de internet y es el estándar dominante en aplicaciones web, móviles y APIs públicas. Su adopción es masiva: Google, Facebook, GitHub, Twitter y prácticamente cualquier plataforma que ofrezca una API pública o la opción de "iniciar sesión con..." utiliza OAuth 2.0. Su extensión OpenID Connect añade la capa de autenticación sobre el protocolo

base de autorización, completando el estándar para los casos de uso de identidad. El ecosistema de OAuth es amplio y cuenta con librerías maduras en prácticamente todos los lenguajes de programación modernos.

SAML 2.0, por su parte, es el estándar dominante en el entorno empresarial y corporativo. Su ecosistema gira en torno a proveedores de identidad como Microsoft Active Directory Federation Services (ADFS), Okta, OneLogin y Ping Identity, así como a aplicaciones empresariales como Salesforce, ServiceNow y plataformas de recursos humanos. SAML es el estándar preferido en sectores como el gobierno, la salud y las finanzas, donde los requisitos de cumplimiento normativo y la infraestructura heredada condicionan las decisiones tecnológicas.

Conceptos de OAuth 2.0 + OIDC

OAuth 2.0 como Protocolo de Delegación

OAuth 2.0 es, en su núcleo, un protocolo de autorización, no de autenticación. Esta distinción es fundamental y frecuentemente malentendida. OAuth 2.0 define cómo un propietario de recursos (Resource Owner) puede autorizar a una aplicación cliente (Client) a acceder a sus recursos protegidos en un servidor de recursos (Resource Server), mediado por un servidor de autorización (Authorization Server). El resultado de este flujo es un token de acceso (access token) de alcance limitado que la aplicación cliente utiliza para realizar operaciones en nombre del usuario.

OAuth 2.0 define cuatro flujos de autorización principales, denominados grant types, diseñados para distintos escenarios de uso. El Authorization Code Grant es el flujo más seguro y recomendado para aplicaciones web con servidor backend. El Implicit Grant, hoy considerado obsoleto por razones de seguridad, fue diseñado para aplicaciones de una sola página. El Client Credentials Grant se utiliza para comunicación entre servidores sin intervención del usuario. El Resource Owner Password Credentials Grant, también desaconsejado actualmente, permitía al cliente recibir directamente las credenciales del usuario.

"OAuth 2.0 is a delegation protocol, a means by which a principal can delegate authorization to a protected resource to another system."
pág. 4²

Capa de Autenticación: OpenID Connect (OIDC)

Dado que OAuth 2.0 es un protocolo de autorización y no de autenticación, la industria desarrolló OpenID Connect (OIDC) como una capa de identidad construida sobre OAuth 2.0. OIDC añade al flujo de OAuth un ID Token, que es un JSON Web Token (JWT) firmado digitalmente que contiene información verificable sobre la identidad del usuario autenticado, incluyendo su identificador único, el emisor del token, la audiencia a la que va dirigido y su tiempo de expiración.

Con OIDC, el servidor de autorización se convierte también en un proveedor de identidad (Identity Provider o IdP) que puede responder preguntas sobre quién es el usuario, no solo qué puede hacer. Adicionalmente, OIDC define el endpoint `/userinfo`, que permite a la aplicación cliente consultar atributos adicionales del usuario como su nombre, correo electrónico o foto de perfil, siempre que el usuario haya otorgado los scopes correspondientes. Esta combinación de OAuth 2.0 + OIDC es hoy el estándar de facto para la autenticación en aplicaciones modernas, utilizado por Google, Microsoft y Apple, entre otros.

Seguridad en OAuth 2.0

La seguridad en OAuth 2.0 depende en gran medida de la correcta implementación del protocolo, ya que el estándar base define el flujo pero no impone todos los mecanismos de protección. Entre las vulnerabilidades más comunes y sus mitigaciones se encuentran las siguientes.

1. Ataques de redirección (`redirect_uri` manipulation): un atacante puede intentar redirigir el código de autorización a una URL controlada por él. La mitigación consiste en registrar las URIs de redirección de forma exacta en el servidor de autorización y validarlas estrictamente.

² Véase OAuth 2.0 in Action, Justin Richer y Antonio Sanso, Manning Publications, capítulo 1, pág. 4.

2. Ataques CSRF en el flujo de autorización: el parámetro state debe ser un valor aleatorio e impredecible que la aplicación cliente verifica al recibir la respuesta del servidor de autorización, vinculando la solicitud a la sesión del usuario.
3. Interceptación del código de autorización (Authorization Code Interception): el estándar PKCE (Proof Key for Code Exchange, RFC 7636) mitiga este riesgo en clientes públicos como aplicaciones móviles, introduciendo un code_verifier y un code_challenge que vinculan la solicitud original con el intercambio del token.
4. Tokens de acceso de larga duración: el uso de refresh tokens de vida corta combinados con access tokens de expiración breve reduce la ventana de exposición ante un token comprometido.

La IETF publica periódicamente guías de mejores prácticas de seguridad para OAuth 2.0, conocidas como OAuth 2.0 Security Best Current Practice (BCP), que documentan las vulnerabilidades conocidas y las mitigaciones recomendadas para cada escenario de implementación.

"Clients MUST prevent CSRF attacks against their redirect URIs. Clients SHOULD use PKCE [...] to prevent authorization code injection attacks." RFC 9700³

Conceptos de SAML 2.0

SAML como Estándar Empresarial

SAML (Security Assertion Markup Language) 2.0 es un estándar XML abierto desarrollado por OASIS en 2005 para el intercambio de datos de autenticación y autorización entre dominios de seguridad distintos. A diferencia de OAuth, que nació en el ecosistema de internet abierto, SAML fue diseñado desde su origen para entornos corporativos donde múltiples organizaciones necesitan federar sus identidades: una empresa que permite a sus empleados acceder a aplicaciones de

³ Véase RFC 9700, OAuth 2.0 Security Best Current Practice. IETF. <https://www.rfc-editor.org/rfc/rfc9700>

proveedores externos usando sus credenciales corporativas sin necesidad de crear cuentas adicionales en cada sistema.

El modelo de SAML define tres roles principales: el Proveedor de Identidad (Identity Provider o IdP), que es quien autentica al usuario y emite las aserciones; el Proveedor de Servicios (Service Provider o SP), que es la aplicación que consume las aserciones para conceder acceso; y el principal, que es el usuario que solicita acceso. La comunicación entre IdP y SP se realiza a través del navegador del usuario mediante redirecciones HTTP que transportan mensajes XML codificados, sin que IdP y SP necesiten comunicarse directamente entre sí en el flujo estándar.

SAML Assertion

La SAML Assertion es el artefacto central del protocolo: es un documento XML firmado digitalmente que el IdP emite para certificar información sobre el usuario autenticado. Una aserción SAML puede contener tres tipos de declaraciones distintas. Primero, la Authentication Statement, que certifica que el usuario fue autenticado por el IdP en un momento determinado y mediante un método específico. Segundo, la Attribute Statement, que transporta atributos del usuario como su nombre, correo, rol o cualquier otro dato que el SP necesite para tomar decisiones de autorización. Tercero, la Authorization Decision Statement, que indica si el usuario tiene permiso para acceder a un recurso específico.

La firma digital de la aserción, basada en XML Signature (XMLDSig), es el mecanismo que garantiza su integridad y autenticidad: el SP puede verificar que la aserción fue emitida por un IdP de confianza y que no ha sido modificada en tránsito. El cifrado de la aserción mediante XML Encryption es opcional pero recomendado cuando la aserción contiene atributos sensibles, ya que sin cifrado el contenido es visible para cualquier intermediario que intercepte la respuesta.

Metadata para el Intercambio de Configuración

Uno de los mecanismos más relevantes de SAML 2.0 desde el punto de vista operativo es el uso de documentos de metadata XML para el intercambio de

configuración entre IdP y SP. El metadata de un IdP contiene, entre otros elementos, sus endpoints de SSO, su certificado de firma pública y los formatos de NameID que soporta. El metadata de un SP contiene sus endpoints de Assertion Consumer Service (ACS), su certificado de cifrado y los atributos que solicita.

Este intercambio de metadata simplifica considerablemente la configuración de una federación SAML: en lugar de configurar manualmente cada parámetro en ambos lados, las organizaciones simplemente intercambian sus documentos de metadata XML, que contienen toda la información necesaria para establecer la confianza mutua. Esta característica es especialmente valiosa en federaciones de gran escala, como las académicas, donde cientos de instituciones participan en un mismo círculo de confianza usando metadata federado gestionado de forma centralizada.

Seguridad en SAML 2.0

La seguridad en SAML 2.0 descansa sobre varios mecanismos criptográficos y de validación que el SP debe implementar correctamente para garantizar la integridad del flujo. Entre los aspectos más relevantes se encuentran los siguientes.

5. Validación de la firma XML: el SP debe verificar la firma de cada aserción recibida contra el certificado público del IdP registrado en su configuración. Una implementación que omita esta validación es vulnerable a ataques de falsificación de aserciones.
6. Verificación del destinatario y la audiencia: la aserción incluye elementos Recipient y AudienceRestriction que el SP debe validar para asegurarse de que la aserción fue emitida específicamente para él y no está siendo reutilizada por un atacante.
7. Control de la ventana de tiempo: las aserciones SAML incluyen condiciones de validez temporal (NotBefore y NotOnOrAfter). El SP debe rechazar aserciones fuera de este rango para prevenir ataques de replay.

8. Prevención de ataques de replay mediante el atributo ID: cada aserción tiene un identificador único. El SP debe mantener un registro de los IDs de aserciones ya procesadas dentro de la ventana de tiempo válida para detectar y rechazar intentos de reutilización.

Un vector de ataque históricamente relevante en implementaciones SAML es el XML Signature Wrapping (XSW), donde un atacante manipula la estructura del documento XML para que la firma válida cubra un elemento distinto al que el SP evalúa para tomar decisiones de acceso. Esta vulnerabilidad ha afectado a múltiples librerías SAML a lo largo de los años y subraya la importancia de utilizar implementaciones maduras y auditadas en lugar de desarrollar parsers SAML propios.

"XML Signature Wrapping attacks exploit the flexibility of XML Signature to present a signed message that appears valid but contains attacker-controlled content in the locations evaluated by the application."
OASIS SAML Security Considerations ⁴

Conclusión

OAuth 2.0 con OpenID Connect y SAML 2.0 son dos respuestas distintas al mismo problema central: cómo delegar identidad de forma segura entre sistemas que no comparten una base de credenciales común. Su diferencia fundamental no es técnica en sentido superficial, sino contextual: OAuth + OIDC fue diseñado para el ecosistema abierto de internet, donde la ligereza, la compatibilidad con dispositivos móviles y la granularidad de permisos son prioritarios. SAML fue diseñado para el ecosistema corporativo y federado, donde la interoperabilidad entre organizaciones con infraestructura heredada y requisitos de cumplimiento normativo condicionan las decisiones.

Desde el punto de vista de la seguridad, ambos estándares son robustos cuando se implementan correctamente, pero sus vectores de ataque difieren. OAuth es vulnerable a ataques sobre el flujo de redirección y la interceptación de tokens si

⁴ Véase RFC 9700, OAuth 2.0 Security Best Current Practice. IETF. <https://www.rfc-editor.org/rfc/rfc9700>

no se aplica PKCE y un manejo adecuado del parámetro state. SAML es vulnerable a ataques de XML Signature Wrapping y replay de aserciones si la validación no es exhaustiva. En ambos casos, la recomendación es consistente: utilizar librerías maduras y auditadas, no implementar el protocolo desde cero.

En la práctica, la elección entre OAuth + OIDC y SAML no siempre es una decisión técnica pura. Con frecuencia la determina el ecosistema existente: si la organización ya cuenta con un IdP SAML como Active Directory Federation Services y necesita integrar aplicaciones empresariales, SAML es la ruta natural. Si se está construyendo una aplicación moderna que necesita integrarse con APIs de terceros o ofrecer inicio de sesión social, OAuth + OIDC es la elección obvia. Y en organizaciones que deben soportar ambos mundos, lo habitual es que el proveedor de identidad central, como Okta o Azure AD, ofrezca soporte simultáneo para ambos protocolos, actuando como puente entre el ecosistema heredado y el moderno.

Bibliografía

1. Richer, J. y Sanso, A. (2017). *OAuth 2.0 in Action*. Manning Publications: <https://manning-content.s3.amazonaws.com/download/9/ae47e1f-0bc2-4805-8288-25531085ef8c/SampleCh01.pdf>
2. Hardt, D. (2012). *RFC 6749, The OAuth 2.0 Authorization Framework*. IETF. <https://www.rfc-editor.org/rfc/rfc6749>
3. Sakimura, N. et al. (2014). *OpenID Connect Core 1.0*. OpenID Foundation. https://openid.net/specs/openid-connect-core-1_0.html
4. IETF (2025). *RFC 9700, OAuth 2.0 Security Best Current Practice*. <https://www.rfc-editor.org/rfc/rfc9700>
5. OASIS (2005). *Assertions and Protocols for the OASIS Security Assertion Markup Language (SAML) V2.0*. <https://docs.oasis-open.org/security/saml/v2.0/saml-core-2.0-os.pdf>
6. Jones, M. y Bradley, J. (2015). *RFC 7636, Proof Key for Code Exchange by OAuth Public Clients (PKCE)*. IETF. <https://www.rfc-editor.org/rfc/rfc7636>